

تقييم المخاطر السيبرانية — المنصة (NIST SP) (800-30 Rev 1)

القسم 04-ksa-compliance النوع assessment الحالة draft المالك Founder آخر تحديث 18-08-2026

أُجري هذا التقييم باستخدام منهجية NIST SP 800-30 Rev 1. يُستخدم إطار NIST هنا كويكل للتقييم فقط؛ بينما يظل نظام حماية البيانات الشخصية (PDPL) واللوائح الصادرة عن سدايا (SDAIA) هي الأطر الملزمة قانونياً.

الخطوة 1 — الإعداد والتحضير

الغرض. إعداد تحليل رصين للمخاطر السيبرانية على مستوى الأنظمة يهدف إلى: (أ) توفير مدخلات تقييم المخاطر للبند 6.1.2 من معيار ISO/IEC 27001 والمطلوبة في `isms-scope-and-statement-of-applicability.md` ، و(ب) تعميق بندي المخاطر السيبرانية في سجل المخاطر العام `09-investor-relations/risk-register.xlsx` ، والذي يمثل مستوى المنشأة ويحتوي حالياً فقط على RR-013 (سوء إعدادات Firebase) وRR-021 (سلسلة إمداد الاعتماديات البرمجية) من أصل 25 بنداً.

النطاق. المستوى 3 — أنظمة الإنتاج التشغيلية المشغلة لموقعي `flygaca.com` و `captadel.com` : تطبيق الويب الميني بـ Vite/React ، وبوابة Firebase Cloud Functions ، وقاعدة بيانات Firestore ، وخدمة الكابتن عادل ، واستضافة Google Cloud الداعمة.

المقياس. الاحتمالية × الأثر، من 1 إلى 5 لكل منهما، متطابق عمداً مع المقياس المعتمد في `risk-register.xlsx` لتتوافق البنود وتُدمج بسلسلة دون الحاجة لإعادة التقييم.

الافتراضات والمحددات — موضحة صراحةً وليست مسكوتاً عنها.

- لم يتم تكليف جهة خارجية باختبار اختراق شامل (Penetration Test)، ولا يوجد فحص ASV مباشر للإنتاج.
- يستند هذا التقييم إلى فحص دفاعي للأدوات أُجري في 18-08-2026 عبر جميع المستودعات الخمسة (فحص الأسرار والرموز في سجل git الكامل، وإشعارات ثغرات الحزم، وفحص SAST لبايثون، ومراجعة سير عمل CI/CD، وتدقيق الترويسات الأمنية). كان لذلك الفحص ثغراته الخاصة: تعذر تشغيل SAST لجافاسكريبت/تايب سكريبت، وعدم توفر ربط NVD/OSV، وعدم الوصول لنقطة نهاية إنتاجية مباشرة. وعدم وجود نتيجة في تلك المجالات لا يُعد دليلاً على خلوها من المخاطر.
- تم استبعاد الخادم الافتراضي في الاتحاد الأوروبي (Hostinger, Paris): فهو يخدم فهرس اللوائح العامة فقط ولا يعالج بيانات شخصية إطلاقاً (`06-operations-it/hosting-facts.md`).

الخطوة 2أ — مصادر التهديد

المعرف	المصدر	النوع	التوصيف
TS-1	مجرم انتحاري	عدائي	هجمات حشو بيانات الاعتماد ألياً، الكشط، وتجربة البطاقات. تعقيد منخفض، حجم كبير
TS-2	مهاجم مستهدف	عدائي	بدافع الوصول لمسار الدفع أو بيانات أكاديميات B2B. تعقيد متوسط
TS-3	طرف في سلسلة الإمداد	عدائي	اختراق حزم npm/PyPI أو إجراءات GitHub Actions بدلاً من استهدافنا مباشرة
TS-4	مستخدم نهائي ضار	عدائي	حساب شرعي يسيء استخدام واجهات النموذج اللغوي أو حصص الاستخدام
TS-5	خطأ المشغل	عرضي	مشغل فردي؛ الأخطاء في الإعدادات هي المصدر العرضي الأبرز
TS-6	انقطاع مزود الخدمة	هيكلي	تعطل إقليمي في Google Cloud
TS-7	تنظيمي / قضائي	بيئي	مخاطر إقامة البيانات الناتجة عن المعالجة الحاسوبية خارج المملكة

الخطوة 2ب-2ج — أحداث التهديد، الثغرات، والظروف المهيئة

الظروف المهيئة — سمات تنظيمية ترفع الاحتمالية أو الأثر بشكل مستقل عن أي ضابط أمني منفرد:

- PC-1 — مشغل فردي. غياب الفصل بين المهام؛ شخص واحد يملك صلاحيات الوصول للإنتاج، ويراجع تغييراته بنفسه، ويمثل نقطة التعافي الوحيدة.
- PC-2 — التركيز في سحابة واحدة. تمثل Google Cloud في الوقت ذاته منصة الحوسبة والمصادقة وقاعدة البيانات واستدلال النماذج اللغوية. اختراق حساب المزود يعني اختراقاً شبه كلي، دون وجود مزود ثانٍ بديل لأي طبقة.
- PC-3 — المعالجة الحاسوبية خارج المملكة. لا تزال دوال Cloud Functions في منطقة `me-central1` (الدوحة) بينما قاعدة Firestore في `me-central2` (الدمام). هذا الوضع موثق ومقبول من المالك مع وجود مسار للهجرة — ولكنه قائم حالياً.
- PC-4 — واجهة دردشة غير موثقة (Unauthenticated). تطبيق App Check على مسار `api/chat/` محكوم بمفتاح تشغيل ومعطّل افتراضياً (`runbooks/runbook-security-rollout.md` 15). سياسة CORS ليست مصادقة أمنية.

الخطوة 2د-2و — تحديد المخاطر

مرتبة حسب درجة التقييم. يميز عمود "الأدلة" بين ما تم رصده وملاحظته في مسح 18-08-2026 وما تم استنتاجه.

المعرف	حدث التهديد	ATT&CK	اح	أث	الدرجة	الأدلة	الضابط القائم
CR-01	خطأ في إعدادات قواعد Firestore يكشف بيانات بين المستخدمين مع إضافة لوحة المدرب لقراءات متعددة	T1530	3	5	15	مستنتج: التصميم مراجع في - pdpl pia-instructor-dashboard.md	بنية الملخص المقيد؛ حزمة اختبارات tests/rules/
CR-02	إجراء GitHub Action مخترق يُنفذ في CI ويسرب أسرار النشر والتوقيع	T1195.001	3	5	15	مرصود — 46 من أصل 46 إجراء عبر المستودعات الخمسة تستخدم وسوماً عائمة (Floating tags)؛ صفر مثبت بالـ SHA استخدام FirebaseExtended/action-hosting-deploy@v0 بيانات اعتماد كاملة	لا يوجد حالياً
CR-03	بقاء بيانات اعتماد حية في سجل git يتم استخراجها وإساءة استخدامها	T1552.001	4	3	12	مرصود — بقاء خمسة أسرار في السجل: أربعة في Money-Printer، ومفتاح Gemini في Captain-Adel. شجرة العمل نظيفة، لكن السجل ليس كذلك؛ لم يتم تدويرها	تنظيف الأطراف؛ التدوير معلق
CR-04	حقن الموجّهات (Prompt injection) يوجّه الكابتن عادل بشكل خاطئ، خاصة بالعربية	ATLAS AML.T0051	4	3	12	مرصود — أنماط الحماية الـ 11 مقتصرّة على الإنجليزية؛ العبارات المقابلة بالعربية لا تُكتشف، فلا تُطبق ملاحظات الحماية في المسار العربي	ضابط فحص مرّن (guards.js)؛ طبقة الاستشهاد والرفض
CR-05	التلاعب بنصوص صفحة الدفع لاعتراض بيانات حاملي البطاقات (Magecart)	T1059.007	2	5	10	مرصود — أداة ميسر تُحقن دون التحقق من تكامل الموارد (SRI)؛ وتعارض أربعة مصادر لـ CSP حول السماح بـ cdn.moyasar.com	سياسة CSP على النطاق المعتمد؛ انظر - pci-dss-scope-and-saq-determination.md

المعرف	حدث التهديد	ATT&CK	اح	أث	الدرجة	الأدلة	الضابط القائم
CR-06	ثغرة في اعتمادية برمجية فرعية (Transitive dependency) تصل للإنتاج	T1195.001	3	3	9	مرصود — 7 تنبيهات متوسطة في مستودعي Node، بجذر مشترك firebase-admin → retry-request → teeny-request تقدير متحفظ: تعذر الوصول لـ NVD/OSV	تفعيل Dependabot في 3 مستودعات
CR-07	استنزاف حصص النموذج اللغوي والتكاليف عبر نقطة الدردشة المفتوحة	T1496	3	3	9	مستنتج من PC-4	تقييد المعدل (Rate limiting)؛ عداد الاستخدام المجاني (مفتوح عند الفشل تصميماً)
CR-08	انقطاع إقليمي في منطقة me-central2 يعطل الخدمة	—	2	4	8	مستنتج	خطة استمرارية الأعمال والتعافي (BCP/DR)
CR-09	مساءلة تنظيمية بسبب معالجة بيانات شخصية خارج المملكة	—	2	4	8	مرصود — PC-3، بالإضافة لتعارض وثيقتين داخليتين حول الواقع الفعلي	مسار هجرة موثق
CR-10	الاستيلاء على الحسابات عبر هجمات حشو بيانات الاعتماد على Firebase Auth	T1110.004	3	2	6	مستنتج	إعدادات Firebase Auth الافتراضية
CR-11	ثغرة تطبيقية غير مكتشفة في كود الويب أو البوابة البرمجية	—	3	3	9	فجوة تغطية وليس دليلاً على السلامة — تعذر تشغيل SAST لجافاسكريبت/تايب سكريبت؛ أكبر مستودعين لم يُفحصا	مراجعة الكود البرمجي فقط

الخطوة 3 — التواصل وإدراج النتائج

الربط مع <09-investor-relations/risk-register.xlsx> :

هذا التقييم	البند القائم في السجل
CR-01	يعتق RR-013 (أخطاء إعدادات Firebase)

هذا التقييم	البند القائم في السجل
CR-02, CR-06	يعتقدان RR-021 (سلسلة إمداد الاعتماديات البرمجية)
CR-08	يرتبط بـ RR-014
CR-03, CR-04, CR-05, CR-09, CR-11	لا يوجد بند قائم — اقتراح إضافتها كبند جديد

يخلو السجل حالياً من بنود كشف بيانات الاعتماد، أو حقن الموجّهات، أو سلامة صفحة الدفع، أو إقامة البيانات، أو تغطية فحص SAST. هذا التقييم يسد هذه الفجوة الجوهرية.

الخطوتان 4-5 — المعالجة والمراقبة

عاجل (خلال أيام):

1. تدوير بيانات الاعتماد الخمسة (CR-03). التأخير يضاعف المخاطر.
 2. تثبيت إجراءات GitHub Actions بقيم SHA وإضافة صلاحيات مقيدة: `permissions:` (CR-02). إجراء آلي مباشر.
 3. إضافة أنماط كشف حقن الموجّهات بالعربية وتغطية التقييمات ثنائية اللغة (CR-04).
 4. اختبارات قواعد Firestore لمنع الوصول بين المدارس وسحب الموافقات في CI قبل إطلاق لوحة التحكم (CR-01).
 5. إضافة معيار SRI أو CSP-nonce لسكربت ميسر؛ ومطابقة مصادر CSP الأربعة (CR-05). 6. تشغيل فحص SAST في CI حيثما توفر الاتصال الخارجي (CR-11).
 7. استكمال الهجرة من `me-central1` إلى `me-central2` (CR-09)، وحل التعارض في `hosting-facts.md`.
 8. تفعيل App Check على مسار `api/chat/` (CR-07, PC-4) وفق الإجراء التدريجي المعتمد.
- دورية المراجعة. سنوياً، أو عند حدوث أي مما يلي: إضافة مسار جديد لتبادل البيانات بين المستخدمين، تغيير في بوابة الدفع، إضافة معالج فرعي جديد، أو احتمال الهجرة الإقليمية. تُحال إجراءات المعالجة إلى جدول `Mitigation Tracker` في سجل المخاطر.

وثائق ذات صلة: `pci-dss-scope-and-saq-determination.md`، `pdpl-pia-instructor-dashboard.md`، `business-information-security-policy.docx`، `isms-scope-and-statement-of-applicability.md`، `09-investor-relations/risk-continuity-and-disaster-recovery-plan-bcp-dr.docx`، `register.xlsx`